

DocuQuery Platform Security Whitepaper

Document ID: SEC-WP-2026-001

Version: 2.1

Published: 2026-03-01

Audience: Enterprise Security Officers, Compliance Teams, Technical Due Diligence

Classification: Public — Distribution Permitted

1. Executive Summary

This whitepaper documents the security architecture, encryption standards, data governance policies, and zero-trust network requirements implemented across the DocuQuery Platform. It is intended to support the security due diligence process for enterprise procurement, SOC 2 Type II audit preparation, and regulatory compliance assessments under GDPR, HIPAA, and ISO/IEC 27001 frameworks.

DocuQuery is designed with a security-first philosophy: every layer of the stack enforces the principle of least privilege, all data is encrypted at rest and in transit, and access to production infrastructure requires multi-factor authentication and hardware-bound credentials.

2. Encryption Standards

2.1 Encryption in Transit

All client-to-service communication is encrypted using **TLS 1.3** as the minimum protocol version. TLS 1.2 is accepted only for legacy integrations via an explicit opt-in configuration flag, which requires written approval from the DocuQuery security team and is automatically sunset after 12 months.

Cipher suites supported (TLS 1.3):

- TLS_AES_256_GCM_SHA384
- TLS_CHACHA20_POLY1305_SHA256
- TLS_AES_128_GCM_SHA256

RSA-based cipher suites are disabled. Only ECDHE-based suites with Perfect Forward Secrecy (PFS) are enabled, ensuring that a future compromise of the server's private key cannot be used to decrypt previously intercepted traffic.

Certificate management: TLS certificates are issued by an internal CA for service-to-service communication and by a publicly trusted CA (DigiCert or Let's Encrypt) for external-facing endpoints. Certificates are automatically rotated 30 days before expiry via the certificate lifecycle management service.

2.2 Encryption at Rest

All persistent data stores used by the DocuQuery Platform are encrypted at rest using **AES-256-GCM**:

Data Store	Encryption Mechanism	Key Management
ChromaDB Vector Index	Volume-level AES-256 (LUKS on Linux)	AWS KMS / Azure Key Vault (customer-selectable)
SQLite Audit Telemetry	SQLite Encryption Extension (SEE) with AES-256	Per-tenant key derived from root KMS key

Document Object Storage (S3/Blob)	Server-Side Encryption (SSE-KMS) with AES-256	Customer-managed KMS key (BYOK supported)
Backup Snapshots	AES-256-GCM with HMAC-SHA512 authentication	Air-gapped backup KMS tier

2.3 Key Management

Encryption key management follows a three-tier hierarchy:

1. **Root Key (KMS-managed):** Stored exclusively in a FIPS 140-2 Level 3 certified Hardware Security Module (HSM). Never leaves the HSM in plaintext. Rotated annually.
2. **Data Encryption Key (DEK):** AES-256 symmetric key used directly for data encryption. Encrypted (wrapped) by the root key and stored alongside the ciphertext. Rotated every 90 days for Enterprise Platinum subscribers, every 180 days for Standard tier.
3. **Per-Request Session Key:** Ephemeral keys used for streaming SSE connections. Derived via HKDF-SHA256 from the DEK and the session identifier. Destroyed at connection termination.

Bring Your Own Key (BYOK): Enterprise Platinum subscribers may supply their own root KMS key, which DocuQuery's HSM infrastructure uses to wrap and unwrap DEKs without ever having access to plaintext tenant data.

3. Data Residency and Sovereignty

3.1 Available Regions

Region	Cloud Provider	Data Sovereignty Compliance
--------	----------------	-----------------------------

EU West (Ireland)	AWS <code>eu-west-1</code>	GDPR, Schrems II compliant
EU Central (Frankfurt)	AWS <code>eu-central-1</code>	GDPR, German BDSG compliant
US East (Virginia)	AWS <code>us-east-1</code>	FedRAMP Moderate (in progress)
US West (Oregon)	AWS <code>us-west-2</code>	CCPA compliant
APAC Southeast (Singapore)	AWS <code>ap-southeast-1</code>	PDPA compliant

Enterprise Platinum subscribers may designate a primary region and a disaster recovery (DR) region. Data does not leave the selected region pair under any operational circumstances. Cross-region replication requires explicit opt-in and is governed by a Data Processing Addendum (DPA).

3.2 Data Classification

DocuQuery classifies all customer data into four categories:

Classification	Examples	Handling
Public	Product documentation, API reference	No special controls
Internal	System logs, metrics, operational telemetry	Access restricted to DocuQuery engineering staff
Confidential	Customer vector indices, query telemetry, uploaded documents	Encrypted at rest and in transit; access logged and auditable
Restricted	Encryption keys, customer credentials, PII	HSM-protected; access requires dual authorisation and is automatically alerted

3.3 Data Retention

Subscriber data retention schedules are defined in the SLA Policy (SLA-POL-2026-001) and are enforced automatically by the Data Lifecycle Manager service. Deletion is cryptographic: the DEK for the tenant is destroyed, rendering all encrypted data permanently irrecoverable, followed by physical block overwriting to prevent forensic recovery from decommissioned storage media.

4. Zero-Trust Network Architecture

4.1 Principles

DocuQuery's production infrastructure operates under a zero-trust network model based on the following principles:

1. **Never trust, always verify.** No service or user is implicitly trusted based on network location. Every request must be authenticated and authorised regardless of whether it originates from inside or outside the production VPC.
2. **Least-privilege access.** Services are granted only the minimum permissions required to fulfil their function. Access is granted per-service, per-operation, and time-bounded where possible.
3. **Assume breach.** Lateral movement is bounded by micro-segmentation. A compromised service cannot reach other services or data stores that it has no legitimate business need to access.
4. **Continuous verification.** Short-lived credentials (maximum 1-hour TTL for service accounts, 8-hour TTL for human operators) ensure that credential rotation reduces the exposure window of any compromised identity.

4.2 Service Mesh and mTLS

All service-to-service communication within the production cluster is mediated by the Envoy sidecar proxy (Istio service mesh). Every RPC between services is authenticated with mutual TLS (mTLS), where both the client and server present certificates issued by the internal CA.

The service mesh enforces:

- **AuthorizationPolicy:** Only explicitly permitted service-to-service communication paths are allowed. By default, all traffic is denied.
- **PeerAuthentication:** mTLS is enforced in `STRICT` mode across all production namespaces. Plaintext connections are rejected at the sidecar layer.

4.3 Network Segmentation

Segment	Services	Ingress Permitted From	Egress Permitted To
DMZ	API Gateway, Load Balancer	Public Internet (HTTPS only)	API Plane
API Plane	FastAPI service, Auth service	DMZ	Storage Plane, LLM Proxy
Storage Plane	ChromaDB, SQLite, S3	API Plane	Backup Plane
LLM Proxy	OpenAI API egress proxy	API Plane	Public Internet (HTTPS to <code>api.openai.com</code> only)
Backup Plane	Backup agents, DR replication	Storage Plane	Off-site encrypted backup targets

Management Plane	Monitoring, logging, CI/CD	Operator VPN only	All planes (read-only telemetry)
------------------	----------------------------	-------------------	----------------------------------

The LLM Proxy is a critical isolation boundary: all outbound calls to the OpenAI API are routed through a dedicated egress proxy that enforces allowlisted domains, strips client-identifying headers from the request, and logs all outbound payloads to the internal audit trail.

4.4 Identity and Access Management

Human access:

- All production console access requires a hardware security key (FIDO2/WebAuthn) as the second factor.
- Session duration is limited to 8 hours for standard operations and 1 hour for privileged (root/admin) operations.
- Just-In-Time (JIT) access provisioning is used for break-glass scenarios; all JIT sessions are automatically recorded and reviewed within 24 hours.

Service accounts:

- Service accounts use SPIFFE/SVID certificates (x.509) issued by the internal SPIRE CA.
- Certificate TTL is 1 hour; automatic rotation is handled by the SPIRE agent on each node.
- Service accounts have no interactive login capability.

5. Application Security

5.1 API Security Controls

Control	Implementation
---------	----------------

Input validation	Pydantic v2 models with <code>extra="forbid"</code> on all inbound DTOs
Injection prevention	Parameterised SQL (? placeholders); no string interpolation in query construction
Rate limiting	Per-API-key token bucket: 100 requests/minute (Standard), 1 000 requests/minute (Platinum)
Request size limits	Maximum request body: 50 MB for file ingestion, 10 KB for query endpoints
Error handling	Domain exceptions mapped to HTTP status codes; no stack traces or internal paths in responses
Secrets management	All credentials read from environment variables via Pydantic Settings; zero hardcoded secrets

5.2 Dependency and Supply Chain Security

All Python dependencies are pinned to exact versions in `pyproject.toml` and validated against the OSV (Open Source Vulnerabilities) database as part of the CI pipeline. Dependencies with known CVEs of CVSS score ≥ 7.0 block the build automatically.

Docker base images are scanned with Trivy on every build. The production image uses `python:3.11-slim` (Debian bookworm) and runs as a non-root user (`appuser`, UID 1001) with a read-only root filesystem where operationally feasible.

5.3 Penetration Testing

DocuQuery conducts external penetration testing annually, performed by a CREST-certified third-party security firm. Test scope covers the API Gateway, authentication flows, vector store access controls, and the LLM egress proxy. Findings are remediated within SLAs defined by severity:

Severity	Remediation SLA
----------	-----------------

Critical (CVSS $\geq$ 9.0)	24 hours
High (CVSS 7.0–8.9)	7 days
Medium (CVSS 4.0–6.9)	30 days
Low (CVSS < 4.0)	90 days

6. Compliance and Certifications

6.1 Current Certifications

Standard	Status	Audit Date	Certificate Expiry
SOC 2 Type II	Certified	2025-11-15	2026-11-14
ISO/IEC 27001:2022	Certified	2025-08-20	2028-08-19
GDPR (DPA available)	Compliant	Ongoing	N/A
HIPAA BAA	Available	Per-contract	N/A

6.2 Audit and Logging

All API requests, administrative actions, and infrastructure mutations are logged to the centralised SIEM (Security Information and Event Management) platform. Logs are:

- Shipped in real time to immutable storage using append-only S3 Object Lock.
- Retained for a minimum of 2 years for regulatory compliance.
- Accessible to subscribers for their own data via the Analytics API (`GET /api/v1/analytics/recent`) and via bulk export on request.

- Protected against tampering by cryptographic hash-chaining (each log block includes the SHA-256 hash of the preceding block, forming an append-only chain).
-

7. Incident Response and Breach Notification

In the event of a confirmed security incident that results in unauthorised access to subscriber data:

1. DocuQuery will notify affected subscribers **within 72 hours** of confirming the breach, in compliance with GDPR Article 33.
 2. Notification will be delivered to the designated Data Protection Officer (DPO) or security contact on file.
 3. Notification will include: nature of the breach, data categories affected, approximate number of records involved, likely consequences, and measures taken or proposed to address the breach.
 4. DocuQuery will provide a detailed post-incident report within 30 days of resolution.
-